Data sharing agreement (controller to controller) (GDPR and DPA 2018)

CONTENTS

CLAUSE

1. Interpretation 1
2. Purpose 3
3. Compliance with the Data Protection Legislation 4
4. Shared Personal Data 4
5. Lawful, fair and transparent processing 5
6. Data quality 5
7. Data subjects' rights 5
8. Data retention and deletion 6
9. Transfers 6
10. Security and training 6
11. Personal data breaches and reporting procedures 7
12. Review and termination of agreement 7
13. Resolution of disputes with data subjects or the Supervisory Authority 8
14. Warranties 8
15. Indemnity 9
16. Allocation of cost 9
17. Limitation of liability 10
18. Third party rights 10
19. Variation 10
20. Waiver 10
21. Severance 11
22. Changes to the applicable law 11
23. No partnership or agency 11
24. Entire agreement 11
25. Further assurance 11
26. Force majeure 12
27. Rights and remedies 12
28. Notice 12
29. Governing law 13
30. Jurisdiction 13

SCHEDULE

Schedule 1 Key legislative provisions and authoritative guidance 14
Schedule 2 Further detail on Shared Personal Data 15
Schedule 3 Deletion procedure 18
Schedule 4 Appropriate technical and organisational security measures 19

This Agreement is dated

PARTIES

(1) **Public Health England (PHE)**, an executive agency of the Department of Health and Social Care with an office at Wellington House, 133-155 Waterloo Road, London SE1 8UG

(2) **XXX Council** whose registered office is at ADDRESS **(Party 2)**

BACKGROUND

(A) PHE agrees to share the Personal Data with Party 2 in the European Economic Area (**EEA**) on terms set out in the Agreement.

(B) Party 2 agrees to use the Personal Data within the EEA on the terms set out in this Agreement.

(C) This is a free-standing Agreement that does not incorporate commercial business terms established by the parties under separate commercial arrangements.

AGREED TERMS

1. Interpretation

The following definitions and rules of interpretation apply in this Agreement.

1.1 Definitions:

Agreed Purpose: has the meaning given to it in clause 2 of this Agreement.

Agreement: this Agreement, which is a free-standing document that does not incorporate commercial business terms established by the parties under separate commercial arrangements.

Business Day: a day; other than a Saturday, Sunday or a public holiday in England; when banks in London are open for business.

Brexit: the UK ceasing to be a member state of the European Union and ceasing to be subject to the transition or implementation arrangements provided for by Part 4 of the withdrawal agreement between the UK and the European Union negotiated under Article 50(2) of the Treaty of the European Union which sets out the arrangements for the UK's withdrawal from the European Union.

Commencement Date: DATE

COPI Notice: the Notice under Regulations 3(1), 3(2), 3(3) & 3(4) of the Health Service Control of Patient Information Regulations 2002 attached with Schedule 1.

Deletion Procedure: has the meaning given to it in clause 8.3 and Schedule 3 to this Agreement.

Data Sharing Code: the Information Commissioner's Data Sharing Code of Practice of May 2011, as updated or amended from time to time.

Data Protection Legislation: all applicable data protection and privacy legislation in force from time to time in the UK including the General Data Protection Regulation (GDPR) (*(EU) 2016/679*); the Data Protection Act 2018; the Privacy and Electronic Communications Directive 2002/58/EC (as updated by Directive 2009/136/EC) and the Privacy and Electronic Communications Regulations 2003 (SI 2003 No. 2426) as amended; any other European Union legislation relating to personal data and all other legislation and regulatory requirements in force from time to time which apply to a party relating to the use of Personal Data (including, without limitation, the privacy of electronic communications) and the guidance and codes of practice issued by the relevant data protection or supervisory authority and applicable to a party.

PowerBI System: a data visualisation tool managed and maintained by Public Health England that allows limited access to data from the NHS test and trace programme.

Shared Personal Data: the personal data and special category personal data to be shared between the parties under clause 2 of this Agreement.

Special Categories of Personal Data: the categories of Personal Data set out in Article 9(1) of the GDPR.

Subject Access Request: the exercise by a data subject of his or her rights under Article 15 of the GDPR and the DPA 2018.

Supervisory Authority: the Information Commissioner.

Term: The duration of the COPI Notice or any extension or continuation thereof.

1.2 **Controller**, **Processor**, **Data Subject** and **Personal Data**, **Processing, Personal Data Breach** and "appropriate technical and organisational measures" shall have the meanings given to them in the Data Protection Legislation.

1.3 Clause, schedule and paragraph headings shall not affect the interpretation of this Agreement.

1.4 The schedules form part of this Agreement and shall have effect as if set out in full in the body of this Agreement. Any reference to this Agreement includes the schedules.

1.5 Unless the context otherwise, requires, words in the singular shall include the plural and in the plural shall include the singular.

1.6 A reference to a company shall include any company, corporation or other body corporate, wherever and however incorporated or established.

1.7 A reference to a statute or statutory provision shall include all subordinate legislation made from time to time under that statute or statutory provision.

1.8 References to clauses and schedules are to the clauses and schedules of this Agreement and references to paragraphs are to paragraphs of the relevant Schedule.

1.9 Any words following the terms **including**, **include**, **in particular** or **for example** or any similar phrase shall be construed as illustrative and shall not limit the generality of the related general words.

1.10 In the case of any ambiguity between any provision contained in the body of this Agreement and any provision contained in the Schedules or appendices, the provision in the body of this Agreement shall take precedence.

1.11 Unless the context otherwise requires, any reference to European Union law that is directly applicable or directly effective in the UK at any time is a reference to it as it applies [in England and Wales from time to time including as retained, amended, extended, or re-enacted or otherwise given effect on or after 11pm on 31 January 2020 OR in EU member states from time to time.

1.12 A reference to **writing** or **written** includes fax and email.

1.13 Unless the context otherwise requires the reference to one gender shall include a reference to the other genders.

2. Purpose

2.1 This Agreement sets out the framework for the sharing of **Personal Data** when one **Controller** (PHE) discloses personal data to another **Controller** (Party 2). It defines the principles and procedures that the parties shall adhere to and the responsibilities the parties owe to each other.

2.2 The parties consider this data sharing necessary to fulfil their responsibilities to take action to manage and mitigate the spread and impact of the current outbreak of Covid-19. These responsibilities are as set out in the COPI Notice.

2.3 The parties agree to only process Shared Personal Data, as described in clause 4.1 and clause 4.2, and Schedule 2, for the following purposes:

(a) understanding Covid-19 and risks to public health, trends in Covid-19 and such risks, and controlling and preventing the spread of Covid-19 and such risks;

(b) processing to support NHS Test and Trace

(c) identifying and understanding information about patients or potential patients with or at risk of Covid-19, information about incidents of patient exposure to Covid-19 and the management of patients with or at risk of Covid-19 including: locating, contacting, screening, flagging and monitoring such patients and collecting information about and providing services in relation to testing, diagnosis, self-isolation, fitness to work, treatment, medical and social interventions and recovery from Covid-19;

(d) understanding information about patient access to health services and adult social care services and the need for wider care of patients and vulnerable groups as a direct or indirect result of Covid-19 and the availability and capacity of those services or that care;

(e) monitoring and managing the response to Covid-19 by health and social care bodies and the Government including providing information to the public about Covid-19 and its effectiveness and information about capacity, medicines, equipment, supplies, services and the workforce within the health services and adult social care services;

(f) delivering services to patients, clinicians, the health services and adult social care services workforce and the public about and in connection with Covid-19, including the provision of information, fit notes and the provision of health care and adult social care services; and

(g) research and planning in relation to Covid-19.

(h) administration and delivery of the Covid-19 Self-Isolation Payment Scheme

2.4 The parties shall not process Shared Personal Data in a way that is incompatible with the purposes described in this clause 2 (**Agreed Purpose**).

2.5 Each party shall appoint a single point of contact (**SPoC**) who will work together to reach an agreement with regards to any issues arising from the data sharing and to actively improve the effectiveness of the data sharing initiative. The points of contact for each of the parties are:

(a) Lee Cramp, DPO at the DHSC (data_protection@dhsc.gov.uk)

(b) SPoC COUNCIL, address

2.6 Under this Agreement, when Party 2 transfers its data to PHE the terms of this Agreement shall apply.

3. Compliance with the Data Protection Legislation

3.1 Each Party must ensure compliance with the Data Protection Legislation at all times during the Term of this Agreement.

3.2 Each Party has such valid registrations and paid such fees as are required by its Supervisory Authority which, by the time that the data sharing is expected to commence, covers the intended data sharing pursuant to this Agreement, unless an exemption applies.

4. Shared Personal Data

4.1 The following types of Personal Data will be shared between the parties during the Term of this Agreement:

(a) Direct personal identifiers (including, address, date of birth, postcode)

(b) Indirect personal identifiers (CTAS ID)

4.2 The following types of Special Categories of Personal Data will be shared between the Parties during the Term of this agreement:

(a) Data concerning a natural person's physical or mental health.

4.3 Further detail on the Shared Personal Data as described in clause 4.1, and clause 4.2 is set out in Schedule 2.

4.4 The Shared Personal Data must not be irrelevant or excessive with regard to the Agreed Purposes.

5. Lawful, fair and transparent processing

5.1 Each Party shall ensure that it processes the Shared Personal Data fairly, transparently and lawfully during the Term of this Agreement.

5.2 Each Party agrees that the legitimate grounds under the Data Protection Legislation for the processing of Shared Personal Data are:

(a) GDPR Article 6(1)(e) 'processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller';

(b) GDPR Article 9(2)(i) 'processing is necessary for reasons of public interest in the area of public health, such as protecting against serious cross-border threats to health or ensuring high standards of quality and safety of healthcare'; and

(c) Data Protection Act 2018 Schedule 1 Part 1 (3) 'public health'.

6. Data quality

6.1 PHE shall take all reasonable steps to ensure that before the Commencement Date, Shared Personal Data are accurate and that it has appropriate internal procedures in place for Party 2 to sample Shared Personal Data prior to the Commencement Date and it will update the same if required prior to transferring the Shared Personal Data.

6.2 Shared Personal Data must be limited to the Personal Data described in clause 4.1 and clause 4.2 and Schedule 2 of this Agreement.

7. Data subjects' rights

7.1 The parties each agree to provide such assistance as is reasonably required to enable the other Party to comply with requests from Data Subjects to exercise their rights under the Data Protection Legislation within the time limits imposed by the Data Protection Legislation.

7.2 The SPoC for each Party is responsible for maintaining a record of individual requests for information, the decisions made and any information that was exchanged. Records must include copies of the request for information, details of the data accessed and shared and where relevant, notes of any meeting, correspondence or phone calls relating to the request. The SPoC for each Party are detailed in clause 2.5.

8. Data retention and deletion

8.1 Party 2 shall not retain or process Shared Personal Data for longer than is necessary to carry out the Agreed Purposes. This should be no longer than 31st December 2021.

8.2 Notwithstanding clause 8.1, parties shall continue to retain Shared Personal Data in accordance with any statutory or professional retention periods applicable in their respective areas of work and profession.

8.3 Party 2 shall ensure that any Shared Personal Data are returned to PHE or destroyed in accordance with the agreed Deletion Procedure set out in Schedule 3 in the following circumstances:

(a) on termination of the Agreement;

(b) on expiry of the Term of the Agreement;

(c) once processing of the Shared Personal Data is no longer necessary for the purposes it was originally shared for, as set out in clause 2.3.

8.4 Following the deletion of Shared Personal Data in accordance with clause 8.3, Party 2 shall notify PHE that the Shared Personal Data in question has been deleted in accordance with the Deletion Procedure in Schedule 3 to this Agreement.

9. Transfers

9.1 For the purposes of this clause, transfers of personal data shall mean any sharing of personal data by Party 2 with a third party, and shall include, but is not limited to, the following:

(a) subcontracting the processing of Shared Personal Data;

(b) granting a third party controller access to the Shared Personal Data.

9.2 If Party 2 appoints a third party processor to process the Shared Personal Data it shall comply with Article 28 and Article 30 of the GDPR and shall remain liable to PHE for the acts and/or omissions of the processor.

9.3 Party 2 shall not disclose or transfer Shared Personal Data outside the EEA.

10. Security and training

10.1 PHE shall only provide the Shared Personal Data to Party 2 by using secure methods as agreed and set out in Schedule 4.

10.2 The parties undertake to have in place throughout the Term appropriate technical and organisational security measures to:

(a) prevent:

(i) unauthorised or unlawful processing of the Shared Personal Data; and

(ii) the accidental loss or destruction of, or damage to, the Shared Personal Data

(b) ensure a level of security appropriate to:

(i) the harm that might result from such unauthorised or unlawful processing or accidental loss, destruction or damage; and

(ii) the nature of the Shared Personal Data to be protected.

10.3 The level of technical and organisational measures agreed by the parties as appropriate as at the Commencement Date having regard to the state of technological development and the cost of implementing such measures is set out in Schedule 4. The parties shall keep such security measures under review and shall carry out such updates as they agree are appropriate throughout the Term.

10.4 It is the responsibility of each Party to ensure that its staff members are appropriately trained to handle and process the Shared Personal Data in accordance with the technical and organisational security measures set out in Schedule 4 together with any other applicable national data protection laws and guidance and have entered into confidentiality agreements relating to the processing of personal data.

10.5 The level, content and regularity of training referred to in clause 10.3 shall be proportionate to the staff members' role, responsibility and frequency with respect to their handling and processing of the Shared Personal Data.

11. Personal data breaches and reporting procedures

11.1 The parties shall each comply with its obligation to report a Personal Data Breach to the appropriate Supervisory Authority and (where applicable) Data Subjects under Article 33 of the GDPR and shall each inform the other Party of any Personal Data Breach irrespective of whether there is a requirement to notify any Supervisory Authority or data subject(s).

11.2 The parties agree to provide reasonable assistance as is necessary to each other to facilitate the handling of any Personal Data Breach in an expeditious and compliant manner.

12. Review and termination of Agreement

12.1 The parties shall review the effectiveness of this data sharing initiative every six months, having consideration to the aims and purposes set out in clause 2.2 and

clause 2.3. The parties shall continue, amend or terminate the Agreement depending on the outcome of this review.

12.2 The review of the effectiveness of the data sharing initiative will involve:

(a) assessing whether the purposes for which the Shared Personal Data is being processed are still the ones listed in clause 2.3 of this Agreement;

(b) assessing whether the Shared Personal Data is still as listed in clause 4.1 and clause 4.2 of this Agreement;

(c) assessing whether the legal framework governing data quality, retention, and data subjects' rights are being complied with; and

(d) assessing whether personal data breaches involving the Shared Personal Data have been handled in accordance with this Agreement and the applicable legal framework.

12.3 Each Party reserves its rights to inspect the other Parties arrangements for the processing of Shared Personal Data and to terminate the Agreement where it considers that the other Party is not processing the Shared Personal Data in accordance with this Agreement.

13. Resolution of disputes with data subjects or the Supervisory Authority

13.1 In the event of a dispute or claim brought by a Data Subject or the Supervisory Authority concerning the processing of Shared Personal Data against either or both parties, the parties will inform each other about any such disputes or claims, and will cooperate with a view to settling them amicably in a timely fashion.

13.2 The parties agree to respond to any generally available non-binding mediation procedure initiated by a data subject or by the Supervisory Authority. If they do participate in the proceedings, the parties may elect to do so remotely (such as by telephone or other electronic means). The parties also agree to consider participating in any other arbitration, mediation or other dispute resolution proceedings developed for data protection disputes.

13.3 Each Party shall abide by a decision of a competent court of PHE’s country of establishment or of the Supervisory Authority.

14. Warranties

14.1 Each Party warrants and undertakes that it will:

(a) Process the Shared Personal Data in compliance with all applicable laws, enactments, regulations, orders, standards and other similar instruments that apply to its personal data processing operations.

(b) Make available on request to the Data Subjects who are third party beneficiaries a copy of this Agreement, unless the Agreement contains confidential information.

(c) Respond within a reasonable time and as far as reasonably possible to enquiries from the relevant Supervisory Authority in relation to the Shared Personal Data.

(d) Respond to Subject Access Requests in accordance with the Data Protection Legislation.

(e) Where applicable, maintain registration with all relevant Supervisory Authorities to process all Shared Personal Data for the Agreed Purpose.

(f) Take all appropriate steps to ensure compliance with the security measures set out in clause 10 above.

14.2 PHE warrants and undertakes that it is entitled to provide the Shared Personal Data to Party 2 and it will take reasonable steps to ensure that the Shared Personal Data are accurate.

14.3 Party 2 warrants and undertakes that it will not disclose or transfer Shared Personal Data outside the EEA.

14.4 Except as expressly stated in this Agreement, all warranties, conditions and terms, whether express or implied by statute, common law or otherwise are hereby excluded to the extent permitted by law.

15. Indemnity

15.1 PHE and Party 2 undertake to indemnify each other and hold each other harmless from any cost, claims, charge, damages, expense (including but not limited to reasonable legal costs) or loss, actions and proceedings which they cause each other as a result of their breach of any of the provisions of this Agreement, except to the extent that any such liability is excluded under clause 17.2.

15.2 Indemnification hereunder is contingent upon:

(a) the Party to be indemnified (the **indemnified Party**) promptly notifying the other Party) (the **indemnifying Party**) of a claim,

(b) the indemnifying Party having sole control of the defence and settlement of any such claim, and

(c) the indemnified Party providing reasonable co-operation and assistance to the indemnifying Party in defence of such claim.

16. Allocation of cost

Each Party shall perform its obligations under this Agreement at its own cost.

17. Limitation of liability

17.1 Neither Party excludes or limits liability to the other Party for:

(a) fraud or fraudulent misrepresentation;

(b) death or personal injury caused by negligence;

(c) a breach of any obligations implied by section 12 of the Sale of Goods Act 1979 or section 2 of the Supply of Goods and Services Act 1982; or

(d) any matter for which it would be unlawful for the parties to exclude liability.

17.2 Subject to clause 17.1, neither Party shall in any circumstances be liable whether in contract, tort (including for negligence and breach of statutory duty howsoever arising), misrepresentation (whether innocent or negligent), restitution or otherwise, for:

(a) any loss (whether direct or indirect) of profits, business, business opportunities, revenue, turnover, reputation or goodwill;

(b) loss (whether direct or indirect) of anticipated savings or wasted expenditure (including management time); or

any loss or liability (whether direct or indirect) under or in relation to any other contract.

18. Third party rights

18.1 Except as expressly provided in clause 7 (data subjects rights) and elsewhere in this Agreement, a person who is not a party to this Agreement shall not have any rights under the Contracts (Rights of Third Parties) Act 1999 to enforce any term of this Agreement. This does not affect any right or remedy of a third party which exists, or is available, apart from that Act.

18.2 No one other than a party to this Agreement, their successors and permitted assignees, shall have any right to enforce any of its terms.

19. Variation

No variation of this Agreement shall be effective unless it is in writing and signed by the Parties (or their authorised representatives).

20. Waiver

No failure or delay by a Party to exercise any right or remedy provided under this Agreement or by law shall constitute a waiver of that or any other right or remedy, nor shall it prevent or restrict the further exercise of that or any other right or remedy. No single or partial exercise of such right or remedy shall prevent or restrict the further exercise of that or any other right or remedy.

21. Severance

21.1 If any provision or part-provision of this Agreement is or becomes invalid, illegal or unenforceable, it shall be deemed deleted, but that shall not affect the validity and enforceability of the rest of this Agreement.

21.2 If any provision or part-provision of this Agreement is deemed deleted under clause 21.1, the parties shall negotiate in good faith to agree a replacement provision that, to the greatest extent possible, achieves the intended commercial result of the original provision.

22. Changes to the applicable law

If during the Term the Data Protection Legislation change in a way that the Agreement is no longer adequate for the purpose of governing lawful data sharing exercises, the Parties agree that the SPoCs will negotiate in good faith to review the Agreement in the light of the new legislation.

23. No partnership or agency

23.1 Nothing in this Agreement is intended to, or shall be deemed to, establish any partnership or joint venture between any of the parties, constitute any party the agent of another party, or authorise any party to make or enter into any commitments for or on behalf of any other party.

23.2 Each Party confirms it is acting on its own behalf and not for the benefit of any other person.

24. Entire agreement

24.1 This Agreement constitutes the entire agreement between the parties and supersedes and extinguishes all previous agreements, promises, assurances, warranties, representations and understandings between them, whether written or oral, relating to its subject matter.

24.2 Each Party acknowledges that in entering into this Agreement it does not rely on, and shall have no remedies in respect of any statement, representation, assurance or warranty (whether made innocently or negligently) that is not set out in this Agreement.

24.3 Each Party agrees that it shall have no claim for innocent or negligent misrepresentation or negligent misrepresentation based on any statement in this Agreement.

25. Further assurance

Each Party shall, and shall use all reasonable endeavours to procure that any necessary third party shall, promptly execute and deliver such documents and perform

such acts as may reasonably be required for the purpose of giving full effect to this Agreement.

26. Force majeure

Neither Party shall be in breach of this Agreement nor liable for delay in performing, or failure to perform, any of its obligations under this Agreement if such delay or failure result from events, circumstances or causes beyond its reasonable control. In such circumstances the affected party shall be entitled to a reasonable extension of the time for performing such obligations. If the period of delay or non-performance continues for three months, the party not affected may terminate this Agreement by giving 30 days' written notice to the affected party.

27. Rights and remedies

Except as expressly provided in this Agreement, the rights and remedies provided under this Agreement are in addition to, and not exclusive of, any rights or remedies provided by law.

28. Notice

28.1 Any notice given to a Party under or in connection with this Agreement shall be in writing, addressed to the SPoCs and shall be:

(a) delivered by hand or by pre-paid first-class post or other next working day delivery service at its registered office (if a company) or its principal place of business (in any other case); or

(b) sent by email to the SPoC.

28.2 Any notice shall be deemed to have been received:

(a) if delivered by hand, on signature of a delivery receipt; and

(b) if sent by pre-paid first-class post or other next working day delivery service, at 9.00 am on the second Business Day after posting or at the time recorded by the delivery service and

(c) if sent by email at the time of transmission, or if this time falls outside business hours in the place of receipt, when business hours resume. In this clause 28.2(c), business hours means 9:00 am to 5:00 pm Monday to Friday on a day that is not a public holiday in the place of receipt.

28.3 This clause does not apply to the service of any proceedings or other documents in any legal action or, where applicable, any arbitration or other method of dispute resolution

29. Governing law

This Agreement and any dispute or claim (including non-contractual disputes or claims) arising out of or in connection with it or its subject matter or formation shall be governed by and construed in accordance with the law of England and Wales.

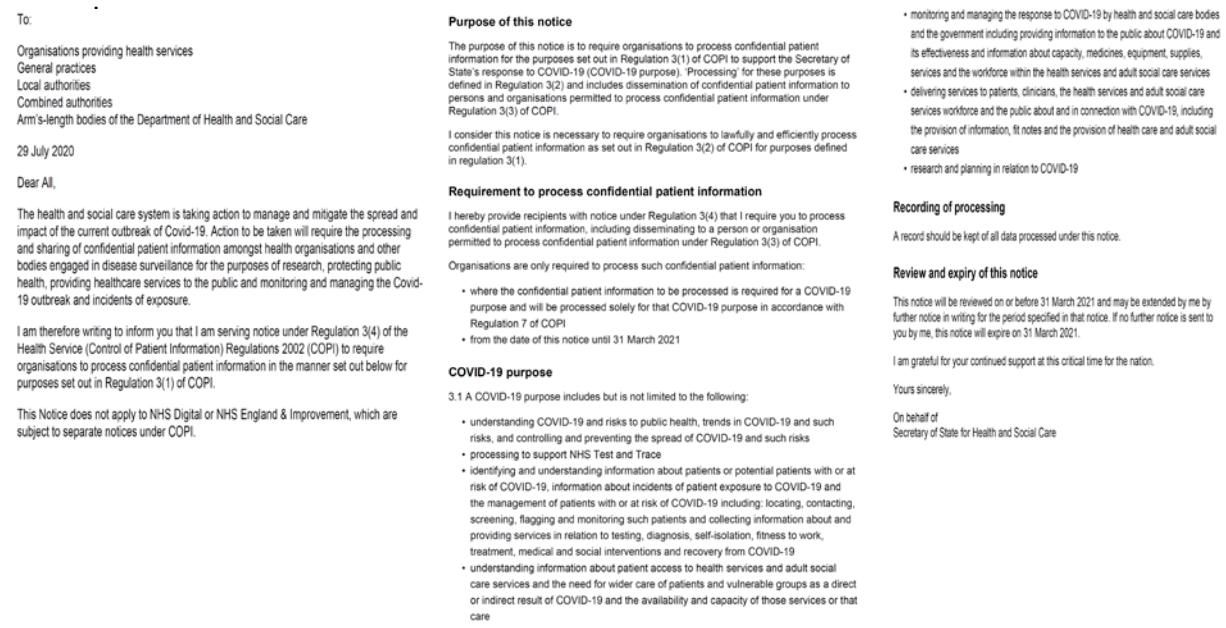
30. Jurisdiction

Each Party irrevocably agrees that the courts of England and Wales shall have exclusive jurisdiction to settle any dispute or claim (including non-contractual disputes or claims), arising out of or in connection with this Agreement or its subject matter or formation.

This Agreement has been entered into on the date stated at the beginning of it.

Schedule 1 Key legislative provisions and authoritative guidance

- The Data Protection Legislation
- *COPI Notice*: Covid-19 – Notice under Regulation 3(4) of the Health Service Control of Patient Information Regulations 2002 (copy attached)



To:

Organisations providing health services
General practices
Local authorities
Combined authorities
Arm's-length bodies of the Department of Health and Social Care

29 July 2020

Dear All,

The health and social care system is taking action to manage and mitigate the spread and impact of the current outbreak of Covid-19. Action to be taken will require the processing and sharing of confidential patient information amongst health organisations and other bodies engaged in disease surveillance for the purposes of research, protecting public health, providing healthcare services to the public and monitoring and managing the Covid-19 outbreak and incidents of exposure.

I am therefore writing to inform you that I am serving notice under Regulation 3(4) of the Health Service (Control of Patient Information) Regulations 2002 (COPI) to require organisations to process confidential patient information in the manner set out below for purposes set out in Regulation 3(1) of COPI.

This Notice does not apply to NHS Digital or NHS England & Improvement, which are subject to separate notices under COPI.

Purpose of this notice

The purpose of this notice is to require organisations to process confidential patient information for the purposes set out in Regulation 3(1) of COPI to support the Secretary of State's response to COVID-19 (COVID-19 purpose). 'Processing' for these purposes is defined in Regulation 3(2) and includes dissemination of confidential patient information to persons and organisations permitted to process confidential patient information under Regulation 3(3) of COPI.

I consider this notice is necessary to require organisations to lawfully and efficiently process confidential patient information as set out in Regulation 3(2) of COPI for purposes defined in regulation 3(1).

Requirement to process confidential patient information

I hereby provide recipients with notice under Regulation 3(4) that I require you to process confidential patient information, including disseminating to a person or organisation permitted to process confidential patient information under Regulation 3(3) of COPI.

Organisations are only required to process such confidential patient information:

- where the confidential patient information to be processed is required for a COVID-19 purpose and will be processed solely for that COVID-19 purpose in accordance with Regulation 7 of COPI
- from the date of this notice until 31 March 2021

COVID-19 purpose

3.1 A COVID-19 purpose includes but is not limited to the following:

- understanding COVID-19 and risks to public health, trends in COVID-19 and such risks, and controlling and preventing the spread of COVID-19 and such risks
- processing to support NHS Test and Trace
- identifying and understanding information about patients or potential patients with or at risk of COVID-19, information about incidents of patient exposure to COVID-19 and the management of patients with or at risk of COVID-19 including: locating, contacting, screening, flagging and monitoring such patients and collecting information about and providing services in relation to testing, diagnosis, self-isolation, fitness to work, treatment, medical and social interventions and recovery from COVID-19
- understanding information about patient access to health services and adult social care services and the need for wider care of patients and vulnerable groups as a direct or indirect result of COVID-19 and the availability and capacity of those services or that care
- monitoring and managing the response to COVID-19 by health and social care bodies and the government including providing information to the public about COVID-19 and its effectiveness and information about capacity, medicines, equipment, supplies, services and the workforce within the health services and adult social care services
- delivering services to patients, clinicians, the health services and adult social care services workforce and the public about and in connection with COVID-19, including the provision of information, fit notes and the provision of health care and adult social care services
- research and planning in relation to COVID-19

Recording of processing

A record should be kept of all data processed under this notice.

Review and expiry of this notice

This notice will be reviewed on or before 31 March 2021 and may be extended by me by further notice in writing for the period specified in that notice. If no further notice is sent to you by me, this notice will expire on 31 March 2021.

I am grateful for your continued support at this critical time for the nation.

Yours sincerely,

On behalf of
Secretary of State for Health and Social Care

Schedule 2 Further detail on Shared Personal Data

Input from Local Authority to PowerBI System:

- CTAS ID - from applicant form

- First part of home address postcode OR applicant date of birth

Output to Local Authority from PowerBI System:

- CTAS ID valid

- start date of isolation

- Postcode

- applicant date of birth

- CTAS ID has been given a payment

Output to Public Health England/Department of Health from Local Authority:

Field	Description	Business Rule	Type/Value
LA_Identifier	Unique name of local authority	Mandatory	60 Char max
CTAS_ID	NULL if applicant has provided no CTAS ID, or if CTAS details from PowerBI do not match other fields	Mandatory	8 char OR NULL if applicant has provided no CTAS ID
Postcode	Postcode from CTAS, if postcode on application is different to CTAS or if it does not match other data fields.	Mandatory	8 char max, no spaces, ie: sw1h0eu
Application_Successful	Was the application successful, for either main fund or discretionary fund. FALSE means the	Mandatory	TRUE FALSE

	application was rejected		
Value_Paid	How much the applicant was paid. NULL/blank/0 values indicated applicant was not paid.	Mandatory if Application_Successful =TRUE, else optional	Format: 0000.00 Positive value, to 2dp. No £ sign
Main_or_Discretionary	Was the applicant paid from main Fund/Discretionary Fund (M/D). NULL/blank means not paid	Mandatory if Application_Successful =TRUE, else optional	M D
Failed_on_criteria_isolate	Applicant has not been asked to self-isolate by NHS Test and Trace and does not have a CTAS ID. NULL/blank is the same as FALSE, and means this the applicant did not fail the criteria	Mandatory if Application_Successful =FALSE, else optional	TRUE FALSE NULL/blank
Failed_on_criteria_employed	Applicant is not employed or self-employed	Mandatory if Application_Successful =FALSE, else optional	TRUE FALSE NULL/blank
Failed_on_criteria_lost	Applicant fails criteria: unable to work from home and will lose income as a result	Mandatory if Application_Successful =FALSE, else optional	TRUE FALSE NULL/blank
Failed_on_criteria_benefit	Applicant fails criteria: in receipt of eligible benefit. Applicant can be successful for discretionary fund, but fail to be in receipt of another benefit.	Mandatory if Application_Successful =FALSE, else optional	TRUE FALSE NULL/blank
Failed_on_criteria_other	Applicant rejected for other reason	Mandatory if Application_Successful =FALSE, else optional	TRUE FALSE NULL/blank
Timestamp	Timestamp for submission	Mandatory	

Payment_Hash	SHA256 hash of the claimant's sort code and bank account number SHA256	Mandatory	hexadecimal output – 64 hex characters

Schedule 3 Deletion procedure

A data destruction certificate must be used to notify PHE of the destruction of the Shared Personal Data.

The terms of this Agreement require confirmation that all the physical and logical data detailed on a data destruction certificate has been destroyed, including the original data and any copies in whole or in part.

The following standards and guidelines are the minimum basis for data decommissioning or destruction:

National Cyber Security Centre (NCSC) guidance on end-user device reset procedures: *https://www.ncsc.gov.uk/guidance/end-user-device-guidance-factory-reset-and-reprovisioning*

NCSC guidance on secure sanitisation of storage media: *https://www.ncsc.gov.uk/guidance/secure-sanitisation-storage-media*

Schedule 4 Appropriate technical and organisational security measures

1. Without prejudice to the Parties' other obligations in respect of information security, the Parties shall:

   1.1 having regard to the state of technological development, provide a level of security (including appropriate technical and organisational measures) appropriate to:

      1.2.1 the harm that might result from unauthorised or unlawful processing of Data or accidental loss, destruction or damage of such Data; and

      1.2.2 the nature of the Data.

   1.2 ensure that access to the Data is limited to those personnel who need access to the Data to meet the Parties obligations under this Agreement;

   1.3 take reasonable steps to ensure the reliability of the Parties' personnel who have access to the Data.

   1.4 inform the other Party as soon as reasonably practicable of any particular risk to the security of the Shared Personal Data of which it becomes aware, and of the categories of Data and individuals which may be affected;

2 The Parties shall implement and maintain security standards, facilities, controls and procedures appropriate to the nature of the Shared Personal Data held by it and the harm that would be caused by its loss or disclosure including a comprehensive and up-to-date data protection policy. The Parties shall ensure that all their personnel who have access to the Data shall comply with the obligations upon them contained in the data protection policy.

3 Each Party shall ensure:

   3.1 that it has properly configured access rights for its personnel including a well-defined joiners and leavers process to ensure access rights to the Data are properly managed;

   3.2 that it has proper controls in place to make sure that complex alphanumeric passwords are required for access to the Shared Personal Data and that training is provided in relation to the need to keep such passwords secure;

   3.3 it has in place procedures to identify wrongful use of Shared Personal Data, including the monitoring of wrongful access to Shard Personal Data;

   3.4 suitable and effective authentication processes are established and used to protect Shared Personal Data;

   3.5 Shared Personal Data is backed up on a regular basis and that all back up data is subject to such vigorous security procedures as are necessary in order to protect data integrity, such security measures being commensurate to the nature of the data. The Parties shall take particular care when transporting backup data and other personal information and shall ensure

such backup data and other personal information is transported in a safe and secure manner;

3.6 Shared Personal Data transferred electronically is encrypted;

3.7 information stored on laptops or other portable media is encrypted and that the Parties maintains an accurate, up to date asset register, including all such portable media used to process the Shared Personal Data;

3.8 that suitable physical security measures are established commensurate to the harm that could result from the unlawful disclosure of the Shared Personal Data. Such physical security measures shall be as identified in the Parties data protection policy;

3.9 without prejudice to the Parties obligations in relation to the disposal of Data, all Data which is disposed of must be disposed of pursuant to the Parties policy for the disposal of Data identified in the data protection policy, including the disposal of assets containing personal data, a copy of which policy shall be provided, on request, to the other Party; and

3.10 the Parties establishes and maintains adequate data security compliance policies and audits its use of personal data in compliance with its data security policies on a regular basis and in any event annually.

4 All data transfers will be via the PowerBI System managed and maintained by PHE.

5 Party 2 confirms that they have a valid Public Services Network (PSN) connection compliance certificate.

6 Additionally, Party 2 shall commit to include any and all devices that transport, access, store or process the shared data must be included in scope for their next Public Services Network (PSN) compliance certificate. As an alternative, Party 2 can confirm that they have completed the NHS Digital Data Security & Protection Toolkit, and are at the following standards:

- 19/20 Standards Exceeded
- 19/20 Standards Met
- 19/20 Standards Not Fully Met (Plan Agreed)

Signed by **Lorraine Jackson**	*Lorraine Jackson*
for and on behalf of **Public Health England** and the **Department of Health and Social Care**	Director, Data & Information Governance, Deputy to Senior Information Risk Owner
Signed by **Paul De Laat**	*Paul De Laat*
for and on behalf of **NHS Test and Trace**	Chief Data Officer
Signed by 	
for and on behalf of **Camden Council**	Chief Executive